My Health @ EU
eHealth Digital Service Infrastructure
A service provided by the European Union

My Health @ EU
eHealth Digital Service Infrastructure
Electronic cross-border health services in the EU

X.509 Certificates Profile

DOCUMENT VERSION 7.0.0

DATE 19/07/2023

STATUS Wave 7 Operation Ready

DG SANTE, MyHealth@EU, 2023
Reuse is authorised, provided the source is acknowledged.

COVER AND CONTROL PAGE OF DOCUMENT	
Document name:	X.509 Certificate Profile
Distribution level*:	PU
Status:	Wave 7 Operation Ready
Author(s): Organization:	eHealth DSI Solution Provider

* Distribution level: PU = Public, PP = Restricted to other programme participants, RE = Restricted to a group specified by the consortium, CO = Confidential, only for members of the consortium.

ABSTRACT
This binding specifies the eHealth DSI profiles on X.509 certificates and CRLs which are used for public key security within eHealth DSI. Common eHealth certificate profiles ensure an equal level of trust among all eHealth DSI countries and are prerequisite to a common understanding of the key characteristics of trustworthy certificates within the eHealth DSI network.

CHANGE HISTORY				
Version	Date	Status Changes	From	Review
V7.0.0	19/07/2023	Wave 7 Operation Ready Administrative Update	eHealth DSI Solution Provider	
V7.0.0	05/06/2023	Wave 7 Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V6.2.0	02/05/2023	Wave 6 – Update of Seal certificate property	eHealth DSI Solution Provider	
V6.1.0	29/07/2022	Wave 6 Operation Ready	eHealth DSI Solution Provider	
V6.0.0	29/04/2022	Wave 6 – Update of the certificate's procedure; update of CEF Digital URLs to FPFIS	eHealth DSI Solution Provider	
V5.0.0	15/06/2021	Wave 5 – Operation Ready (adopted by eHMSEG on 15/06/2021)	eHealth DSI Solution Provider	
V5.0.0	30/04/2021	Wave 5 Release Candidate – Updating SOD eHealth PKI to v1.3	eHealth DSI Solution Provider	
V4.0.0	15/05/2020	Wave 4 Release Candidate - Integration of CEF	eHealth DSI Solution Provider	

		eDelivery PKI		
V3.0.0	02/07/2019	Wave 3 Operation Ready - Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V2.2.0	08/06/2018	Wave 2 Operation Ready	eHealth DSI Solution Provider	
V2.1.7	30/05/2018	Wave 1 Operation Ready – Versioning re-labelling for consistency	eHealth DSI Solution Provider	eHDSI Test Partner
V2.1.6 (Previously 2.2.2)	10/10/2017	eHDSI Deploying Countries early feedback	eHealth DSI Solution Provider	CEF eSIG Expert
V2.1.5 (Previously 2.2.1)	21/09/2017	Final update	eHealth DSI Solution Provider	eHDSI Deploying Countries
V2.1.4 (Previously 2.2)	21/09/2017	Final draft update	eHealth DSI Solution Provider	CEF eSIG Expert
V2.1.3	26/07/2017	Updated according to CA recommendations	eHealth DSI Solution Provider	
V2.1.2	12/07/2017	Consolidated version based on the eSignature Experts recommendation	eHealth DSI Solution Provider	
V2.1.1	28/06/2017	Remove IPSec Certificates and OCSP Responder	eHealth DSI Solution Provider	
V2.1.0	01/06/2017	Released for eHMSEG adoption	eHealth DSI Solution Provider	
V2.0.2	23/05/2017	Certificates profiles review as follow up from the CEF eDelivery PKI request for clarification	eHealth DSI Solution Provider	
V2.0.1	21/04/2017	Integrate the modifications linked to the CP-002	eHealth DSI Solution Provider	
V2.0.0	28/03/2017	Remove all references to epSOS and requirements	eHealth DSI Solution Provider	
V1.0	17/12/2013	Alignment with release documents	Fraunhofer FOKUS	

TABLE OF CONTENTS

1 Use of Public Key Security in eHealth DSI 5

1.1 The X.509 Standard *5*

1.2 Related Documents *6*

1.3 Conventions *6*

1.4 Terms and Definitions *6*

1.5 Status of this Binding *7*

2 General Considerations 7

2.1 Tests vs. Operations *7*

2.2 Algorithms and Key Length *7*

2.3 Certificate Issuing Authorities *7*

2.4 Certificate Verification *8*

3 eHealth DSI Certificate Profiles 8

3.1 Certificate Profiles *8*

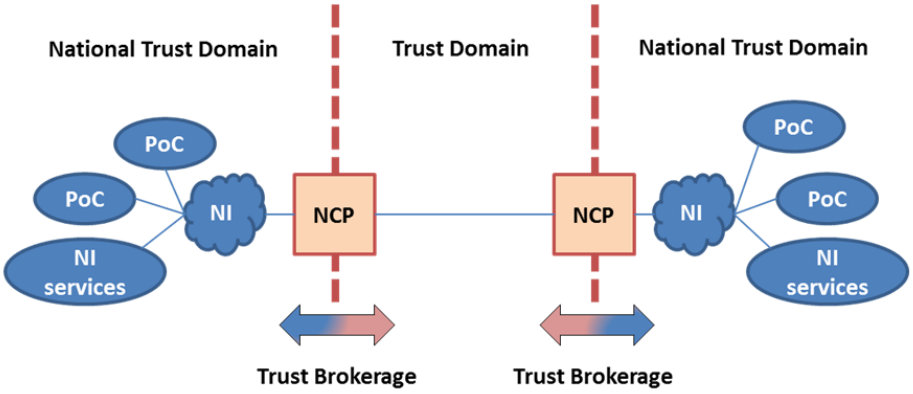
3.2 Certificate Revocation Lists *10*

3.2.1 CRL Profile – General Stipulation 10

4 References 11

1 Use of Public Key Security in eHealth DSI

eHealth DSI does not establish direct end-to-end trust relationships between data producers and data consumers. Instead, eHealth DSI security relies on a "brokered trust" paradigm [Interoperability Specification] where NCPs act as trust brokers between a national infrastructure (NI) and the eHealth DSI domain. NCPs are bound to the eHealth DSI trust domains as well as to their national trust domain. As such they are assumed as trusted by other NCPs and by all services and actors within their respective national infrastructure.



Establishing an eHealth DSI Trust Domain among NCPs has many facets to consider:

- NCPs MUST be able to verify the authenticity of other NCPs
- NCPs MUST be able to establish a closed network on top of a public network
- NCPs MUST be able to establish secure messaging channels with other NCPs
- NCPs MUST be aware of the integrity and authenticity of requests and data which are received from another NCP
- NCPs MUST be able to extract authoritative information about the peer's identity for documentation and audit trail purposes

For implementing these requirements, eHealth DSI makes use of Public Key Infrastructure (PKI) comprising cryptography, certificates, and digital signatures. This binding specifies the respective certificates to be used.

1.1 The X.509 Standard

PKI are based on the ITU-T X.509 standard that specifies formats for public key certificates, certificate revocation lists (CRL), attribute certificates, and means for certification path validation.

This binding specifies the eHealth DSI profiles on X.509 certificates and CRLs which are used for public key security within eHealth DSI. Common eHealth certificate profiles ensure an equal level of trust among all eHealth DSI countries and are prerequisite to a common understanding of the key characteristics of trustworthy certificates within the eHealth DSI network.

1.2 Related Documents

Algorithms and key lengths to be used for implementing the eHealth DSI X.509 certificate profiles are specified in [Cryptographic Algorithms].

Other eHealth DSI documents must refer to this binding as [X.509 Certificate Profiles]. Unless a version number is given, references to [X.509 Certificate Profiles] always refer to the most current version that is published on the eHealth DSI website.

1.3 Conventions

The keywords MUST, SHOULD, MAY, SHOULD NOT and MUST NOT are used as defined in [RFC 2119].

eHealth DSI requirements are managed within a central requirements management tool and serialized into [Requirements and Recommendations]. References to requirements always use the identifiers as used with the central requirements. Newly defined requirements are handed over to the central requirements management. In case of doubt or conflict, [Requirements and Recommendations] MUST be considered to be the normative phrasing of a requirement.

1.4 Terms and Definitions

The term "**Healthcare Professional (HP)**" denotes a doctor of medicine, a nurse responsible for general care, a dental practitioner, a midwife or a pharmacist within the meaning of Directive 2005/36/EC, or another professional exercising activities in the healthcare sector which are restricted to a regulated profession as defined in Article 3(1)(a) of Directive 2005/36/EC, or a person considered to be a health professional according to the legislation of the country of treatment [eHealth DSI Glossary]. Health professionals are allowed to process medical patient data according to the legislation of the country of the health professional's residence.

An "**eHealth DSI Point of Care (PoC)**" is a location where an eHealth DSI patient may seek healthcare services [eHealth DSI Glossary].

A "**National Contact Point (NCP)**" is an entity in each particular country to act as a bidirectional technical, organizational and legal interface between the existing national functions and infrastructures [eHealth DSI Glossary]. In this document the term "NCP" emphasizes the technical aspects of this interface and as such refers to a gateway which facilitates various aspects of cross-border data sharing (e.g. message forwarding, signature verification).

A **"Conformity Assessment Body (CAB)**" means a body defined in point 13 of Article 2 of Regulation (EC) No 765/2008, which is accredited in accordance with that Regulation as competent to carry out conformity assessment of a trust service provider and the trust services it provides.

1.5 Status of this Binding

The binding as defined in this document is a normative binding. All eHealth DSI countries MUST implement this binding within their NCP. Additional or alternative bindings MUST NOT be defined and implemented for the eHealth DSI.

2 General Considerations

2.1 Tests vs. Operations

eHealth DSI countries MAY use different certificates for eHealth DSI testing and eHealth DSI operations.

Security relaxations MUST NOT be applied to operational certificates.

The operational certificates MAY be used for testing.

The testing certificates MUST NOT be used for eHealth DSI routine operations.

2.2 Algorithms and Key Length

All cryptographic objects and algorithms contained with eHealth DSI compliant certificates MUST follow the "eHealth DSI Cryptographic Keys and Algorithms" guidelines [Cryptographic Algorithms].

For testing [Cryptographic Algorithms] defines several security relaxations, that also MAY be applied to eHealth DSI certificates which are used during testing.

Relaxations MUST NOT be applied to certificates which are used for eHealth DSI operations.

2.3 Certificate Issuing Authorities

All certificates used for eHealth DSI operations MUST be issued by a trust service provider issuing certificates in line with the [eIDAS-Regulation]

All certificates used for eHealth DSI operations SHOULD be issued in compliance with the [ETSI EN 319 411-1] defined Normalized Certificate Policy or the [ETSI EN 319 411-1] defined Extended Validation Certificate Policy for TLS certificates.

Trust service provider and the trust services they use to issue certificates used for eHealth DSI operations MUST be audited at their own expense at least every 24 (twenty-four) months by a conformity assessment body for their compliance against the requirements of the present document.

2.4 Certificate Verification

Each certificate that is received by a NCPeH as part of a security handshake or within a digital signature MUST be verified by that NCPeH.

The following verifications apply to both testing and operational certificates:

- The current date MUST be within the validity range of the certificate.
- The certificate MUST NOT be revoked.
- Algorithms and key length MUST comply to [Cryptographic Algorithms].

The following verifications MUST be applied to operational certificates and MAY be omitted for testing certificates:

- The certificate SHOULD include the eHealth DSI certificate policy OID (see chapter 3).

The use of the certificate MUST be compliant with its key usage element as specified for the respective certificate profile (see chapter 3).

3 eHealth DSI Certificate Profiles

All certificates used as extended validation certificates for the establishment of eHealth DSI SHOULD comply with [ETSI EN 319 412-4], with the amendments specified in chapter 3.1.

eHealth DSI compliant X.509 certificates used for the establishment of electronic seals [eIDAS-Regulation] SHOULD comply with [ETSI EN 319 412-3] in line with Normalized Certificate Policy requirements [ETSI EN 319 411-1], with the amendments specified in chapter 3.1.

3.1 Certificate Profiles

Note: When not further specified, the requirements specified in the description of an element listed in the table below are applicable to all types of eHealth DSI certificates identified in chapter 3.1. When preceded by **[TLS]**, the requirements specified in the description of an element are only applicable to eHealth DSI compliant X.509 TLS/SSL certificates. Elements whose description is preceded by **[Seal]** are only applicable to eHealth DSI compliant X.509 certificates used for the establishment of electronic seals.

Element	Description
Signature algorithm	"eHealth DSI Cryptographic Keys and Algorithms" recommendations [Cryptographic Algorithms] MUST be followed.
Serial number	The serial number MUST be an unambiguous positive integer value with a maximum of 20 bytes.
Validity from/to	Certificates used by eHealth DSI services SHOULD be valid for a maximum of 3 years.
IssuerUniqueID	The field "IssuerUniqueID" MUST NOT be used.
SubjectUniqueID	The field "SubjectUniqueID" MUST NOT be used.
Subject	(a) The Subject-DName MUST remain unambiguous over the entire lifetime of the CA. (b) The minimal attributes DName MUST have: C (Country), O (Organization) and CN (Common Name). (c) The attribute OU (Organizational Unit) MAY be used. (d) String lengths MUST be limited as follows: - C (Country)→ 2 bytes ([ISO 3166-1] Alpha 2 code) - O (Organization)→ max. 64 bytes - CN (Common Name)→ max. 64 bytes - OU (Organizational Unit)→ max. 64 bytes (e) When applicable, the DName attributes MUST be coded in UTF8. A subset (Unicode Latin-1 page - ANSI/ISO 8859-1)

	SHOULD be used.
Issuer	The DName MUST be identical to the subject DName of the Issuer certificate.
Extensions	
Authority Key Identifier (non-critical)	(a) "Authority KeyIdentifier" MUST be included as an extension in the certificate. (b) The "SubjectKeyIdentifier" of the issuing CA MUST be used. (c) AuthorityCertIssuer and AuthorityCertSerialNumber SHOULD NOT be used as AuthorityKeyIdentifier.
Subject Key Identifier (non-critical)	(a) "SubjectKeyIdentifier" MUST be included as an extension in the certificate (b) One of the methods described in clause 4.2.1.2 of [RFC 5280] MUST be used.
KeyUsage (critical)	(a) "KeyUsage" MUST be included as an extension in the certificate. (b) The extension MUST be designated as critical. (c) **[TLS]:** The digitalSignature and keyEncipherment bits MUST both be set to true to the exclusion of all other KeyUsage bits that MUST be set to false, excepted for the dataEncipherment bit that MAY be set to true. (d) **[Seal]:** The digitalSignature and keyEncipherment bits MUST both be set to true to the exclusion of all other KeyUsage bits that MUST be set to false.
IssuerAltNames (non-critical)	(a) "IssuerAltNames" MAY be included as an extension in the certificate.
SubjectAltNames (non-critical)	(a) "SubjectAltNames" MAY be included as an extension in the certificate. (b) If this extension is used, a corresponding LDAP-, HTTP- or FTP-URL SHOULD be provided. (c) E-Mail addresses (RFC822-name) [RFC 822] MAY also be made available.
BasicConstraints	(a) "BasicConstraints" MUST be included as an extension in the certificate.
Extended Key Usage (non-critical)	**[Seal]** "ExtendedKeyUsage" MUST NOT be included as an extension in the certificate. **[TLS]** Both values id-kp-serverAuth [RFC5280] and id-kp-clientAuth [RFC5280] MUST be present.
CRL Distribution Points (non-critical)	(a) "CRLDistributionPoints" SHOULD be included as an extension in the certificate. (b) If the certificate does not include any access location of an OCSP responder as specified in "AIA extension", then the certificate MUST include a CRL distribution point extension. (c) When present, the CRL distribution point extension MUST include at least one reference to a publicly available CRL. (d) At least one of the present references MUST use either http (http://) [RFC 7230-7235] or ldap (ldap://) [RFC 4516] scheme. (e) The extension shall not be marked critical.
Certificate Policies (non-critical)	"CertificatePolicies" SHOULD be included as an extension in the certificate to include the eHealth DSI certificate policy identifier: 1.3.130.0.2017.*ARES_number_of_the_present_document*
Authority Info Access (non-critical)	(a) "AuthorityInfoAccess" SHOULD be included as an extension in the certificate. (b) When OCSP is supported by the issuing CA, the Authority Information Access extension MUST include an accessMethod OID, id-ad-ocsp, with an accessLocation value specifying at least one access location of an OCSP [RFC 6960] responder authoritative to provide certificate status information for the present certificate. (c) When present, at least one access location MUST specify either the http (http://) [RFC 7230-7235] or https (https://) [RFC 2818] scheme to reference a publicly available OCSP responder, which accepts unsigned and unauthenticated

	status requests. (d) A reference to at least one OCSP responder MUST be present if the certificate does not include any CRL distribution point extension in accordance with requirements on "CRL Distribution Points". (e) When the issuing CA is not represented by a self-signed root certificate, the Authority Information Access extension MUST include an accessMethod OID, id-ad-caIssuers, with an accessLocation value specifying at least one access location of a valid CA certificate of the issuing CA. At least one access location shall use the http (http://) IETF RFC 7230-7235 scheme or https (https://) IETF RFC 2818 scheme. This requirement MAY be ignored altogether when the issuing CA is represented by a self-signed root certificate.
QCStatement	(a) **[TLS]** The esi4-qcStatement-6 id-etsi-qcs-QcType 3 statement SHOULD be included on its own as specified in [ETSI EN 319 412-5] to indicate that it is used for the purposes of electronic website authentication. (b) **[Seal]** The esi4-qcStatement-6 id-etsi-qcs-QcType 2 SHOULD be included on its own as specified in [ETSI EN 319 412-5] to indicate that it is used for the purposes of electronic seal.

3.2 Certificate Revocation Lists

CRLs can be used to check whether a certificate has been declared invalid or revoked. Both the client and server/service MUST reciprocally check the validity of all certificates against the CRL before transmitting data to the counterpart. If the certificate is invalid, the connection is terminated.

The following section defines the profile (structure) of a CRL, and all CRLs issued by the CA are to be based on these guidelines. The following guidelines refer to direct CRLs.

3.2.1 CRL Profile – General Stipulation

CRLs profile MUST comply with [RFC 5280] with the following amendments:

Element	Description
Version	CRLs to be deployed MUST be v2.
Signature algorithm	"eHealth DSI Cryptographic Keys and Algorithms" recommendations [Cryptographic Algorithms] MUST be followed.
Issuer	The DName MUST be identical to the subject DName of the issuer certificate.
Validity from/to (thisUpdate/nextUpdate)	The CRL's period of validity (from/to) MUST be stated.
Extensions Only the extensions presented here SHOULD be employed.	
Authority KeyIdentifier	The KeyIdentifier MUST be indicated.
CRLNumber	(a) The consecutive number for the CRL issued MUST be indicated (b) It MUST have a unique positive integer value with a maximum length of 20 bytes.
IssuerAltNames	(a) "IssuerAltNames" MAY be an extension in the CRL (b) If this extension is used, a corresponding LDAP-URL from which the issuer certificate can be called up SHOULD be provided. (c) HTTP and FTP URLs that refer to the certificate MAY also be provided.

4 References

[Public Key Infrastructure] MyHealth@EU - Certificates Procedure Request https://webgate.ec.europa.eu/fpfis/wikis/x/BgSEPg

[eIDAS-Regulation] REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC
http://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:32014R0910&from=EN

[ETSI EN 319 411-1] Electronic Signatures and Infrastructures (ESI); Policy and security requirements for Trust Service Providers issuing certificates; Part 1: General requirements.
http://www.etsi.org/deliver/etsi_en/319400_319499/31941101/01.01.01_60/en_31941101v010101p.pdf

[ETSI EN 319 412-3] Electronic Signatures and Infrastructures (ESI); Certificate Profiles; Part 3: Certificate profile for certificates issued to legal persons.
http://www.etsi.org/deliver/etsi_en/319400_319499/31941203/01.00.00_20/en_31941203v010000a.pdf

[ETSI EN 319 412-4] Electronic Signatures and Infrastructures (ESI); Certificate Profiles; Part 4: Certificate profile for web site certificates.
http://www.etsi.org/deliver/etsi_en/319400_319499/31941204/01.01.01_60/en_31941204v010101p.pdf

[ETSI EN 319 412-5] Electronic Signatures and Infrastructures (ESI); Certificate Profiles; Part 5: QCStatements.
http://www.etsi.org/deliver/etsi_en/319400_319499/31941205/02.01.01_60/en_31941205v020101p.pdf

[ISO 3166-1] ISO 3166-1:2013: "Codes for the representation of names of countries and their subdivisions - Part 1: Country codes".

[RFC 0822] Crocker, D.: Standard for ARPA Internet Text Messages. August 1982.
https://www.ietf.org/rfc/rfc0822.txt

[RFC 2119] Bradner, S.: Key words for use in RFCs to Indicate Requirement Levels. Harvard University, Boston, Massachusetts, 1997.

[RFC 4516] IETF RFC 4516: "Lightweight Directory Access Protocol (LDAP): Uniform Resource Locator".

[RFC 5280] X.509 Network WG: Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. May 2008.
https://www.ietf.org/rfc/rfc5280.txt

[RFC 6960] IETF RFC 6960: "X.509 Internet Public Key Infrastructure Online Certificate Status Protocol - OCSP".

[RFC 7230-7235] IETF RFC 7230 to RFC 7235: "Hypertext Transfer Protocol -- HTTP/1.1".

[RFC 2818] IETF RFC 2818: "HTTP Over TLS".